

SECURE PAYMENT SYSTEM ARCHITECTURE

Design and Implementation for PayLink Africa

Submitted By:
Chibuike Ambless Adiele

Program:
Cybersecurity Diploma – Altschool Africa

Course:
Fundamentals of Security Architecture

Assignment Title:
Designing a Secure System Architecture

Submission Date:
19th March 2026

Designing a Secure System Architecture for PayLink Africa

Introduction

PayLink Africa is a fintech platform designed to support online payments, digital wallets, and API-based integrations with merchants and financial institutions. Because the platform processes highly sensitive financial and personal data, security must be embedded into the architecture from the ground up. A secure system architecture ensures that customer data, payment transactions, and system resources remain protected against cyber threats while maintaining reliable service availability.

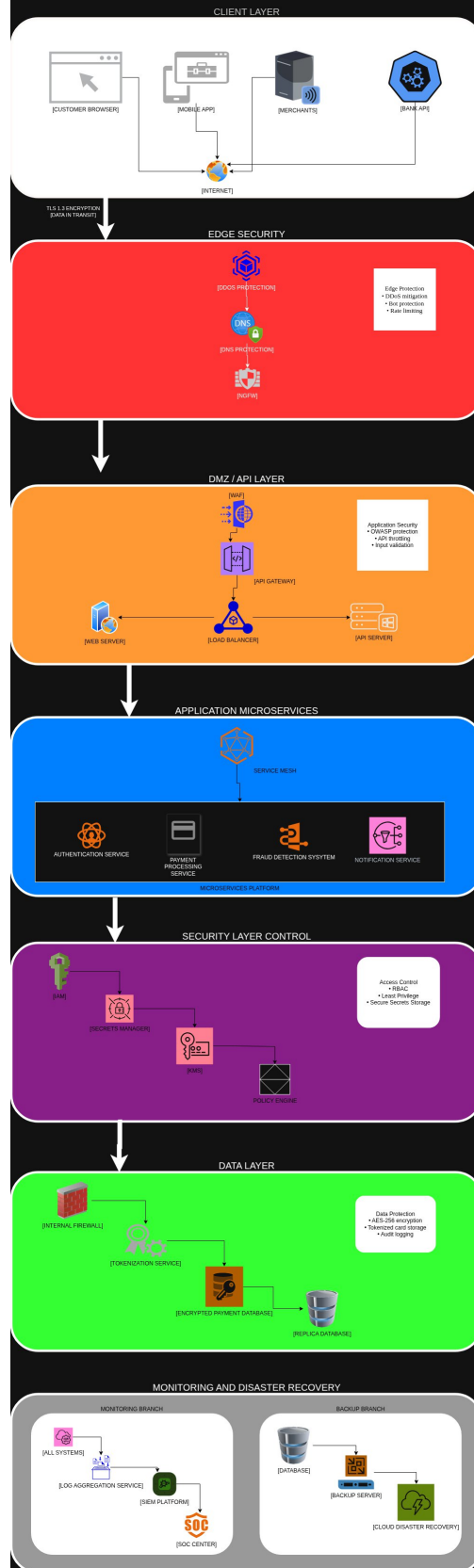
The architecture presented in this design follows key security principles including the **Confidentiality, Integrity, and Availability (CIA) triad**, **defense in depth**, and the **principle of least privilege**. The design also aligns with recognized security frameworks such as NIST SP 800-53 and ISO/IEC 27001. These frameworks guide organizations in implementing effective security controls and managing information security risks.

The architecture is organized into multiple layers, including the client layer, edge security layer, DMZ/API layer, application microservices layer, security control layer, data layer, and monitoring and disaster recovery systems. Each layer provides specific security protections that collectively ensure the system remains secure and resilient.

Secure Payment System Architecture
PayLink Africa Fintech Platform

Architecture based on Zero-Trust principles and aligned with NIST SP 800-53 and ISO/IEC 27001 controls.

Course: Fundamentals of Security Architecture
Author: Chibuike Adiele
Date: March 2026



Threat Mitigation Examples

SQL Injection → WAF + Input Validation
DDoS Attack → Edge DDoS Protection
Credential Theft → MFA Authentication
Insider Threat → Least Privilege Access

CIA SECURITY MODEL

- Confidentiality**
 - TLS encryption
 - Tokenized card data
- Integrity**
 - API validation
 - Transaction hashing
- Availability**
 - Load balancing
 - Database replication
 - Disaster recovery

Enforcing the CIA Triad

Confidentiality

Confidentiality ensures that sensitive information such as customer credentials, payment data, and transaction records is accessible only to authorized users. In this architecture, confidentiality is enforced through multiple mechanisms.

First, all communications between clients and the system are protected using **TLS 1.3 encryption**, ensuring that data transmitted over the internet cannot be intercepted or read by unauthorized parties. Within the data layer, financial information is protected using **AES-256 database encryption**, which secures stored payment and customer data.

Additionally, a **tokenization service** replaces sensitive card data with secure tokens before storage, minimizing exposure of real payment information. Identity and Access Management (IAM) also ensures that only authenticated users and services can access specific resources within the platform.

Integrity

Integrity ensures that financial transactions and system data remain accurate and protected from unauthorized modification. PayLink Africa enforces integrity through secure application design and transaction validation.

Incoming requests are inspected by a **Web Application Firewall (WAF)** that filters malicious inputs and protects against application attacks such as SQL injection and cross-site scripting. The API gateway further validates requests and enforces rate limiting to prevent abuse.

Within the application microservices layer, transaction validation and secure API processing ensure that payment operations are performed correctly. Audit logs generated throughout the system allow administrators to track and verify all transactions, supporting accountability and tamper detection.

Availability

Availability ensures that users can access the payment platform whenever needed. Because fintech systems require high uptime, several mechanisms are used to maintain service continuity.

A **load balancer** distributes traffic across multiple web and API servers to prevent service disruption due to high demand. The database layer includes **replication**, allowing a backup database instance to take over if the primary database fails.

In addition, regular system backups are stored through a **cloud disaster recovery system**, ensuring that data can be restored in the event of hardware failures, cyberattacks, or accidental data loss.

Defense in Depth and Least Privilege

The architecture follows a **defense in depth strategy**, where multiple layers of security controls protect the system from different types of threats.

At the perimeter, **edge security controls** such as DDoS protection, DNS protection, and a next-generation firewall filter incoming traffic before it reaches the internal network. Within the DMZ layer, the Web Application Firewall and API gateway protect web applications and APIs from common vulnerabilities.

The application layer contains isolated microservices connected through a **service mesh**, which enforces secure communication between services. This ensures that even internal components must authenticate before interacting with each other.

The architecture also implements the **principle of least privilege**, which restricts access rights to the minimum required for each user or system component. Identity and Access Management controls determine which services can access specific resources, while the secrets manager and key management system securely store authentication credentials and cryptographic keys.

Threats and Mitigation Strategies

Several common threats to fintech platforms were considered during the design of this architecture.

One major threat is **SQL injection**, where attackers attempt to manipulate database queries to access sensitive information. This risk is mitigated through the use of a Web Application Firewall and strong input validation at the application layer.

Another potential threat is **Distributed Denial of Service (DDoS)** attacks that attempt to overwhelm the platform with traffic. The edge security layer includes dedicated DDoS protection systems that filter malicious traffic before it reaches the core infrastructure.

A third threat involves **credential theft**, where attackers attempt to compromise user accounts through phishing or brute-force attacks. The system mitigates this risk by implementing **multi-factor authentication (MFA)** and strong identity verification controls.

Finally, **insider threats** are addressed by enforcing least privilege access policies and maintaining detailed audit logs that track system activity.

Reflection

Hardest Part of Designing the Architecture

The most challenging aspect of designing the architecture was determining how to balance strong security controls with system performance and usability. Implementing multiple layers of security improves protection but can also introduce additional complexity and potential latency if not properly configured.

Careful placement of security mechanisms such as firewalls, API gateways, and authentication systems was necessary to ensure the system remained secure while maintaining efficient processing of financial transactions.

Architecture Changes for a Fully Cloud-Based System

If PayLink Africa operated entirely in a cloud environment, many of the infrastructure components would be replaced with managed cloud services. For example, cloud providers offer built-in DDoS protection, web application firewalls, identity management systems, and scalable databases.

Cloud-native architectures would also support automated scaling and distributed deployments across multiple availability zones, further improving system availability and resilience.

Lessons Learned About Security, Cost, and Usability

This assignment highlighted the importance of balancing security, operational cost, and user experience when designing secure systems. While implementing numerous security controls can significantly improve protection, organizations must consider the financial and operational impact of these measures.

Effective security architecture therefore requires strategic decision-making that prioritizes the most critical risks while maintaining system performance and usability for legitimate users.